Committee on National Security Systems

(U) CNSSP 22
September 2021

CYBERSECURITY

RISK MANAGEMENT

THIS DOCUMENT PRESCRIBES MINIMUM STANDARDS
YOUR DEPARTMENT OR AGENCY MAY REQUIRE FURTHER
IMPLEMENTATION

CHAIR

FOREWORD

1. The Committee on National Security Systems (CNSS) Policy (CNSSP) 22 provides the following guidance for organizations that own, operate, or maintain national security systems (NSS) to:

a. Establish an integrated, organization-wide Cybersecurity Risk Management Program to achieve and maintain an acceptable level of cybersecurity risk. Implementing a Cybersecurity Risk Management Program provides a framework for decision makers allowing them to evaluate and prioritize cybersecurity risks and determine appropriate mitigations.

b. Implement reciprocity to facilitate information sharing. Participating organizations entering into reciprocal agreements shall share and reuse existing data and information included within Risk Management Framework (RMF) core documents in support of authorization and risk acceptance decisions.

c. Integrate cybersecurity risk management into the system's life cycle. Aligning cybersecurity risk management with other organizational business and mission risk management processes provides ongoing cybersecurity integration.

2. Adherence to this Policy fosters trust among organizations that own, operate, or maintain NSS by providing a standardized framework for cybersecurity processes and best practices and ensuring a common understanding of how organizations safeguard shared information.

3. As part of the Joint Task Force Transformation Initiative Working Group, the CNSS is working with representatives from the Civil, Defense, and Intelligence Communities to produce a unified information security framework by facilitating common publications to the maximum extent possible. Harmonized security guidance is expected to minimize duplication of effort, reduce maintenance costs, and maximize effective implementation of controls across multiple interconnected systems. In addition, harmonized guidance should make it simpler and more cost-effective for vendors and contractors to supply security products and services to the federal government.

4. The CNSS adopts National Institute of Standards and Technology (NIST) issuances where applicable. CNSS issuances will be published when the needs of NSS are not sufficiently addressed in a NIST document. Annex A identifies the guidance documents, which include

NIST Special Publications (SP), for establishing an organization-wide Cybersecurity Risk Management Program. Annex A will be updated as necessary.

5. This policy is available from the CNSS Secretariat, as noted below, or the CNSS website: www.cnss.gov.

/s/
RICHARD A. HALE

CNSS Secretariat (C074) National Security Agency. 9800 Savage Road, Suite 6165 - Ft Meade MD 20755-6165
(410)-854-6805
cnss@nsa.gov

CYBERSECURITY RISK MANAGEMENT

SECTION I—PURPOSE

1. CNSSP 22 requires the implementation of an integrated, organization-wide program for managing cybersecurity risk to organizational operations (i.e., mission, functions, image, and reputation), organizational assets, individuals, other organizations, and the Nation resulting from the operation and use of NSS. Risk management is a comprehensive process that requires organizations to frame, assess, respond to, and monitor risk. This Policy is implemented based upon issuances listed in Annex A, which provide a detailed approach to cybersecurity risk management.

SECTION II—AUTHORITY

2. CNSSP 22 is issued pursuant to National Security Directive 42, National Policy for the Security of National Security Telecommunications and Information Systems (Reference 1), which outlines the roles and responsibilities for securing NSS, and applicable sections of the Federal Information Security Modernization Act (FISMA) of 2014 (Reference 2).

3. Nothing in this policy shall alter or supersede the authorities of the Director of National Intelligence.

SECTION III—SCOPE

4. CNSSP 22 applies to all United States Government (USG) Departments and Agencies (as defined in Reference 2), their employees, and contractors who own, operate, or maintain NSS.

SECTION IV—POLICY

5. All organizations that own, operate, or maintain NSS must establish and implement an organization-wide NSS Cybersecurity Risk Management Program that is integrated with mission and business risk management to ensure organizational operations.

6. In support of an NSS Cybersecurity Risk Management Program, organizations must:

a. Establish a risk executive (function) as identified in NIST SP 800-39, Managing Information Security Risk: Organization, Mission, and Information System View (Reference 3); guide and oversee the organization's cybersecurity risk management program; develop and maintain a cybersecurity risk management strategy; communicate organization-wide cybersecurity threat, vulnerability, and risk-related information; and provide a strategic view for managing cybersecurity risk throughout the organization.

b. Conduct risk assessments and identify cybersecurity risks from an organization-wide perspective consistent with NIST SP 800-30, Guide for Conducting Risk Assessments (Reference 4); determine which risks are acceptable consistent with the organizations defined risk tolerance.

c. Use the common control concept, as described in NIST SP 800-53, Security and Privacy Controls for Federal Information Systems and Organizations (Reference 5), throughout the organization consistent with its enterprise architecture, to select, implement, assess, and continuously monitor security controls within the organization.

d. Develop new and maintain existing organizational policies and procedures to integrate cybersecurity risk management throughout the information system lifecycle (e.g., acquisition, design, development, integration, distribution, operation, maintenance, and retirement) leveraging and integrating systems security engineering within systems engineering.

e. Develop an integrated standard for data elements within RMF core documents to establish consistency and facilitate reciprocity across the NSS community in accordance with CNSS Instruction (CNSSI) 1254, Risk Management Framework Documentation and Data Elements Standards for National Security Systems (Reference 6).

f. Develop and implement an organization-wide information security continuous monitoring (ISCM) strategy and program to provide awareness of threats and vulnerabilities, visibility into organizational assets, and the effectiveness of deployed security controls.

SECTION V—RESPONSIBILITIES

7. In accordance with FISMA, heads of USG Departments and Agencies, to include independent bureaus and offices, are responsible for the overall cybersecurity risk management within their organizations and must:

a. Establish a Cybersecurity Risk Management Program to support the implementation of CNSSP 22, including Annex A issuances.

b. Integrate cybersecurity risk management into organizational policies and practices throughout the information systems lifecycle (e.g., acquisition, design, development, integration, distribution, operation, maintenance, and retirement).

c. Establish cybersecurity risk management processes that are efficient, effective, and maximize the assurance of organizational operations.

d. Conduct ongoing review of threats, vulnerabilities, technologies, and mission changes to assess their impact to the organizational risk posture.

e. Refer NSS-related cybersecurity risk issues that cannot be resolved between or among USG Departments and Agencies to the governing departmental Information System Risk Management Committees (ISRMCs).

f. Provide their organization's Risk Management Framework (RMF) core documents consisting of required RMF data elements and RMF documents, as described in Reference 6, when entering into reciprocal agreements.

SECTION VI—DEFINITIONS

8. All terms used in this issuance are defined in CNSS Instruction (CNSSI No. 4009, *National IA Glossary).*

SECTION VIII - REFERENCES

9. Annex B lists referenced documents. Future updates to referenced documents shall be considered applicable to this policy.

.

Enclosures:
ANNEX A—Cybersecurity Risk Management Issuances
ANNEX B—References

ANNEX A

CYBERSECURITY RISK MANAGEMENT ISSUANCES

1. The following CNSS issuances are specific to establishing organization-wide Cybersecurity Risk Management Programs within the national security community:

a. CNSSI 1253, *Security Categorization and Control Selection for National Security Systems* (Reference 8), adopts the security controls catalogued in NIST SP 800-53, and concepts from FIPS PUB 199, as adapted for use with NSS. It also provides guidance for categorizing NSS and the information it processes, baseline sets of controls for NSS based on the system categorization, developing and applying overlays, and parameter values for security controls appropriate to set at the CNSS level. CNSSI 1253 is a companion document to the NIST publications relevant to categorization and selection (Reference 5).

b. CNSSI 1254, *Risk Management Framework Documentation, Data Element Standards, and Reciprocity Process for National Security Systems* (Reference 6), creates an integrated standard for data elements within RMF core documents to establish consistency and facilitate reciprocity across the NSS community. CNSSI 1254 is a companion document to the NIST publications relevant to Risk Management Framework documentation.

2. The following documents are applicable to the national security community to establish an organization-wide Cybersecurity Risk Management Program:

a. NIST SP 800-39, *Managing Information Security Risk: Organization, Mission, and Information System View* (Reference 3), provides guidance for an integrated, organization-wide program for managing information security risk to organizational operations (i.e., mission, functions, image, and reputation), organizational assets, individuals, other organizations, and the Nation resulting from the operation and use of federal information systems. This document, as written, is applicable to organizations that employ NSS.

b. NIST SP 800-37, *Guide for Applying the Risk Management Framework to Federal Information Systems* (Reference 9), provides guidelines for applying the Risk Management Framework to federal information systems to include conducting the activities of security categorization, security control selection, implementation, security control assessment, information system authorization, and security control monitoring. This document, as written, is applicable to the organizations that employ NSS.

c. NIST SP 800-53, *Security and Privacy Controls for Federal Information Systems and Organizations* (Reference 5), provides guidance on the process for selecting security controls, as well as providing the security controls applicable to all federal government information systems. Portions of this document are applicable to the national security community, as described in CNSSI 1253 (Reference 8).

d. NIST SP 800-53A, *Assessing Security and Privacy Controls in Federal Information Systems and Organizations: Building Effective Assessment Plans* (Reference 10), provides guidelines for building effective security assessment plans and a comprehensive set of procedures for assessing the effectiveness of security controls employed in information systems supporting the executive agencies of the federal government. This document, as written, is applicable to organizations that employ NSS. Supplemental documents may be necessary to address NSS-specific assessment requirements and recommendations for topics unique to NSS.

e. NIST SP 800-30, *Guide for Conducting Risk Assessments* (Reference 4), provides guidance for conducting risk assessments of federal information systems and organizations, amplifying the guidance in NIST SP 800-39. This document provides guidance for carrying out each of the steps in the risk assessment process and how risk assessments and other organizational risk management processes complement and inform each other. This document, as written, is applicable to the organizations that employ NSS.

f. Federal Information Processing Standard (FIPS) Publication (PUB) 199, *Standards for Security Categorization of Federal Information and Information Systems* (Reference 11), provides standards for categorizing information and information systems. The security categories are based on the potential impact on an organization should certain events occur which jeopardize the information and information systems needed by the organization to accomplish its assigned mission, protect its assets, fulfill its legal responsibilities, maintain its day-to-day functions, and protect individuals. Security categories are to be used in conjunction with vulnerability and threat information in assessing the risk to an organization. This document, as written, is applicable to organizations that employ NSS.

3. The following documents may be leveraged by the national security community to establish an organization-wide Cybersecurity Risk Management Program:

a. NIST SP 800-137, *Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations* (Reference 12), assists organizations in the development of an ISCM strategy and the implementation of an ISCM program that provides awareness of threats and vulnerabilities, visibility into organizational assets, and the effectiveness of deployed security controls.

b. NIST SP 800-60 Volume I, *Guide for Mapping Types of Information and Types of Information Systems to Security Categories* (Reference 13), addresses the FISMA direction to develop guidelines recommending the types of information and information systems to be included in each category of potential security impact. This guideline is intended to help agencies consistently map security impact levels to types of: (i) information (e.g., privacy, medical, proprietary, financial, contractor sensitive, trade secret, investigation); and (ii) information systems (e.g., mission critical, mission support, administrative).

c. NIST SP 800-60 Volume II, *Appendices to Guide for Mapping Types of Information and Types of Information Systems to Security Categories* (Reference 14), includes security categorization recommendations and rationale for mission-based and management and support information types.

ANNEX B

REFERENCES

1. (U) *National Security Directive 42, National Policy for the Security of National Security Telecommunications and Information Systems, 5 July 1990.*

2. (U) *Public Law No: 113-283, Federal Information Security Modernization Act (FISMA) of 2014.*

3. *(U) NIST SP 800-39, Managing Information Security Risk: Organization, Mission, and Information System View, March 2011.*

4. *(U) NIST SP 800-30, Revision 1, Guide for Conducting Risk Assessments, September 2012.*

5. *(U) NIST SP 800-53 Rev 5, Security and Privacy Controls for Federal Information Systems and Organizations, September 2020.*

6. *(U) CNSSI 1254, Risk Management Framework Documentation, Data Element Standards, and Reciprocity Process for National Security Systems, (August 2016).*

7. *(U) CNSSI 4009, Committee on National Security Systems (CNSS) Glossary, 6 April 2015.*

8. *(U) CNSSI 1253, Security Categorization and Control Selection for National Security Systems, March 2014.*

9. *(U) NIST SP 800-37 Rev 2, Guide for Applying the Risk Management Framework to Federal Information Systems: A Security Life Cycle Approach for Security and Privacy, December 2018.*

10. *(U) NIST SP 800-53A, Assessing Security and Privacy Controls in Federal Information Systems and Organizations: Building Effective Assessment Plans, December 2014.*

11. *(U) FIPS PUB 199, Standards for Security Categorization of Federal Information and Information Systems, February 2004.*

12. *(U) NIST SP 800-137, Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations, September 2011.*

13. *NIST SP 800-60 Volume I, Guide for Mapping Types of Information and Information Systems to Security Categories, August 2008.*

14. NIST SP 800-60 Volume II, Appendices to Guide for Mapping Types of Information and Information Systems to Security Categories, August 2008.